FICHE 3 – IMPLIQUER ET FORMER LES UTILISATEURS

Faire prendre conscience à chaque utilisateur des enjeux en matière de sécurité et de vie privée.

Les erreurs humaines et les attaques par ingénierie sociale sont à l'origine d'un nombre important d'incidents de sécurité. Les solutions techniques ne sont pas suffisantes pour assurer la protection des données personnelles détenues par un organisme.

Les précautions élémentaires

- **Sensibiliser les utilisateurs (aussi bien internes qu'externes à l'organisme) travaillant avec des données personnelles aux risques liés aux libertés et à la vie privée des personnes**, les informer des mesures prises pour traiter ces risques et des conséquences potentielles en cas de manquement. Concrètement, il peut s'agir :
  - d'organiser des séances de sensibilisation sur les risques, les principaux types d'attaques (ex. : hameçonnage ou « *phishing* », rançongiciel ou « *ransomware* », usurpation d'identité), la vigilance nécessaire (ex. : avant d'ouvrir une pièce jointe ou de cliquer sur un lien dans un message, lorsqu'on répond au téléphone) et la conduite à tenir en cas d'incident ou de suspicion (mesures de protection et d'alerte) ;
  - de faire des rappels réguliers et en fonction de l'actualité de l'organisme (ex. : tentative de hameçonnage récente, arrivée d'un nouveau prestataire) des consignes.
- Déployer différentes campagnes de sensibilisation dont **le contenu et le langage sont adaptés aux fonctions des destinataires.** Par exemple, les ressources humaines doivent être sensibilisées aux données qu'elles manipulent et les employés qui interviennent à l'extérieur, aux risques particuliers du nomadisme.
- S'assurer que les personnels en charge de traitements de données personnelles (ex. : ceux en charge du traitement de réclamations ou de documents administratifs) ont bien assimilé les bonnes pratiques relatives à la protection des données personnelles à mettre en œuvre au quotidien (ex. : évaluation des connaissances).
- Former les personnels en charge des outils informatiques (ex. : ceux en charge de la conception et de la maintenance) à la sécurité informatique et à la protection des données personnelles.
- **Documenter les procédures d'exploitation**, les tenir à jour et les rendre disponibles à tous les utilisateurs concernés. Concrètement, toute action sur un traitement de données personnelles, qu'il s'agisse d'une opération d'administration ou de la simple utilisation d'une application, doit être expliquée dans un langage clair et adapté à chaque catégorie d'utilisateurs, dans des documents auxquels ces derniers peuvent se référer.

Ce qu'il ne faut pas faire

- Imposer des outils informatiques sans accompagner leur adoption par les équipes.
- Ne pas imposer de session obligatoire sur la protection des données personnelles à tout nouvel arrivant, quand l'activité principale de l'organisme traite des données personnelles (ex. : établissement de santé, service client).
- Sous-estimer l'impact positif que des collaborateurs bien sensibilisés peuvent avoir sur la sécurité informatique de l'organisme.
- Ne pas veiller à la sensibilisation des prestataires extérieurs (par action directe ou par engagement contractuel) quand leur impact sur la sécurité des données peut être aussi important que celui des collaborateurs internes.